



Agliberto e Pedro - Locação de video games

Site: <http://localhost:8080>

Generated on **qui., 23 abr. 2026 02:17:18**

ZAP Version: 2.17.0

ZAP by [Checkmarx](#)

Summary of Alerts

Nível de Risco	Number of Alerts
Alto	1
Médio	4
Baixo	3
Informativo	4

Insights

Level	Motivo	Site	Descrição	Statistic
Médio	Exceeded Low		Percentage of memory used	80
Baixo	Atenção		ZAP errors logged - see the zap.log file for details	14
Baixo	Atenção		ZAP warnings logged - see the zap.log file for details	9
Informações	Informativo	http://localhost:8080	Percentage of responses with status code 2xx	82 %
Informações	Informativo	http://localhost:8080	Percentage of responses with status code 3xx	1 %
Informações	Informativo	http://localhost:8080	Percentage of responses with status code 4xx	4 %

Informações	Exceeded Low	http://localhost:8080	Percentage of responses with status code 5xx	12 %
Informações	Informativo	http://localhost:8080	Percentage of endpoints with content type application/json	24 %
Informações	Informativo	http://localhost:8080	Percentage of endpoints with content type image/gif	4 %
Informações	Informativo	http://localhost:8080	Percentage of endpoints with content type text/css	4 %
Informações	Informativo	http://localhost:8080	Percentage of endpoints with content type text/html	65 %
Informações	Informativo	http://localhost:8080	Percentage of endpoints with method GET	87 %
Informações	Informativo	http://localhost:8080	Percentage of endpoints with method POST	12 %
Informações	Informativo	http://localhost:8080	Count of total endpoints	49
Informações	Informativo	http://localhost:8080	Percentage of slow responses	1 %
Informações	Informativo	https://archive.mozilla.org	Percentage of responses with status code 2xx	100 %
Informações	Informativo	https://archive.mozilla.org	Percentage of endpoints with content	100 %

			type application /x-xpinstall	
Informações	Informativo	https://archive.mozilla.org	Percentage of endpoints with method GET	100 %
Informações	Informativo	https://archive.mozilla.org	Count of total endpoints	1
Informações	Informativo	https://archive.mozilla.org	Percentage of slow responses	100 %

Alertas

Nome	Nível de Risco	Number of Instances
Injeção SQL	Alto	7
Ausência de tokens Anti-CSRF	Médio	Systemic
Estouro de Buffer	Médio	5
Missing Anti-clickjacking Header	Médio	Systemic
Session ID in URL Rewrite	Médio	Systemic
Application Error Disclosure	Baixo	1
Divulgação de informações - Mensagens de Erro de Depuração	Baixo	1
Referer Exposes Session ID	Baixo	Systemic
Information Disclosure - Sensitive Information in URL	Informativo	Systemic
Modern Web Application	Informativo	Systemic
Solicitação de autenticação identificada	Informativo	5
User Controllable HTML Element Attribute (Potential XSS)	Informativo	12

Alert Detail

Alto	Injeção SQL
Descrição	SQL injection may be possible.
URL	http://localhost:8080/h2-console/login.do?jsessionid=ce55e78d9eb9a35eef4e02d1abb3cb5f
Node Name	http://localhost:8080/h2-console/login.do (jsessionid)(driver,language,name,password,setting,url,user)
Método	POST
Ataque	org.h2.Driver AND 1=1 --
Evidence	
	The page results were successfully manipulated using the boolean conditions [org.h2.Driver AND 1=1 --] and [org.h2.Driver AND 1=2 --]

Other Info	The parameter value being modified was stripped from the HTML output for the purposes of the comparison. Data was returned for the original parameter. The vulnerability was detected by successfully restricting the data originally returned, by manipulating the parameter.
URL	http://localhost:8080/h2-console/settingRemove.do?jsessionId=ce55e78d9eb9a35eef4e02d1abb3cb5f
Node Name	http://localhost:8080/h2-console/settingRemove.do (jsessionid)(driver,language,name,password,setting,url,user)
Método	POST
Ataque	JjGoXzGv OR 1=1 --
Evidence	
Other Info	The page results were successfully manipulated using the boolean conditions [JjGoXzGv AND 1=1 --] and [JjGoXzGv OR 1=1 --] The parameter value being modified was stripped from the HTML output for the purposes of the comparison. Data was NOT returned for the original parameter. The vulnerability was detected by successfully retrieving more data than originally returned, by manipulating the parameter.
URL	http://localhost:8080/h2-console/settingSave.do?jsessionId=ce55e78d9eb9a35eef4e02d1abb3cb5f
Node Name	http://localhost:8080/h2-console/settingSave.do (jsessionid)(driver,language,name,password,setting,url,user)
Método	POST
Ataque	org.h2.Driver" AND "1"="1" --
Evidence	
Other Info	The page results were successfully manipulated using the boolean conditions [org.h2.Driver" AND "1"="1" --] and [org.h2.Driver" AND "1"="2" --] The parameter value being modified was stripped from the HTML output for the purposes of the comparison. Data was returned for the original parameter. The vulnerability was detected by successfully restricting the data originally returned, by manipulating the parameter.
URL	http://localhost:8080/h2-console/settingSave.do?jsessionId=ce55e78d9eb9a35eef4e02d1abb3cb5f
Node Name	http://localhost:8080/h2-console/settingSave.do (jsessionid)(driver,language,name,password,setting,url,user)
Método	POST
Ataque	Generic H2 (Server)" OR "1"="1" --
Evidence	
Other Info	The page results were successfully manipulated using the boolean conditions [Generic H2 (Server)" AND "1"="1" --] and [Generic H2 (Server)" OR "1"="1" --] The parameter value being modified was stripped from the HTML output for the purposes of the comparison. Data was NOT returned for the original parameter.

	The vulnerability was detected by successfully retrieving more data than originally returned, by manipulating the parameter.
URL	http://localhost:8080/h2-console/test.do?jsessionId=ce55e78d9eb9a35eef4e02d1abb3cb5f
Node Name	http://localhost:8080/h2-console/test.do (jsessionid)(driver,language,name,password,setting,url,user)
Método	POST
Ataque	SkersxgA AND 1=1
Evidence	
Other Info	The page results were successfully manipulated using the boolean conditions [SkersxgA AND 1=1] and [SkersxgA AND 1=2] The parameter value being modified was stripped from the HTML output for the purposes of the comparison. Data was returned for the original parameter. The vulnerability was detected by successfully restricting the data originally returned, by manipulating the parameter.
URL	http://localhost:8080/h2-console/test.do?jsessionId=ce55e78d9eb9a35eef4e02d1abb3cb5f
Node Name	http://localhost:8080/h2-console/test.do (jsessionid)(driver,language,name,password,setting,url,user)
Método	POST
Ataque	ru AND 1=1 --
Evidence	
Other Info	The page results were successfully manipulated using the boolean conditions [ru AND 1=1 --] and [ru AND 1=2 --] The parameter value being modified was stripped from the HTML output for the purposes of the comparison. Data was returned for the original parameter. The vulnerability was detected by successfully restricting the data originally returned, by manipulating the parameter.
URL	http://localhost:8080/h2-console/test.do?jsessionId=ce55e78d9eb9a35eef4e02d1abb3cb5f
Node Name	http://localhost:8080/h2-console/test.do (jsessionid)(driver,language,name,password,setting,url,user)
Método	POST
Ataque	UxUaCjAE AND 1=1 --
Evidence	
Other Info	The page results were successfully manipulated using the boolean conditions [UxUaCjAE AND 1=1 --] and [UxUaCjAE AND 1=2 --] The parameter value being modified was stripped from the HTML output for the purposes of the comparison. Data was returned for the original parameter. The vulnerability was detected by successfully restricting the data originally returned, by manipulating the parameter.
Instances	7
	Do not trust client side input, even if there is client side validation in place. In general, type check all data on the server side.

Solution	If the application uses JDBC, use PreparedStatement or CallableStatement, with parameters passed by '?'
	If the application uses ASP, use ADO Command Objects with strong type checking and parameterized queries.
	If database Stored Procedures can be used, use them.
	Do *not* concatenate strings into queries in the stored procedure, or use 'exec', 'exec immediate', or equivalent functionality!
	Do not create dynamic SQL queries using simple string concatenation.
	Escape all data received from the client.
	Apply an 'allow list' of allowed characters, or a 'deny list' of disallowed characters in user input.
	Apply the principle of least privilege by using the least privileged database user possible.
	In particular, avoid using the 'sa' or 'db-owner' database users. This does not eliminate SQL injection, but minimizes its impact.
	Grant the minimum database access that is necessary for the application.
Reference	https://cheatsheetseries.owasp.org/cheatsheets/SQL_Injection_Prevention_Cheat_Sheet.html
CWE Id	89
WASC Id	19
Plugin Id	40018

Médio	Ausência de tokens Anti-CSRF
Descrição	Não foram localizados tokens Anti-CSRF no formulário de submissão HTML.
	Uma falsificação de solicitação entre sites (Cross-Site Request Forgery ou simplesmente CSRF) é um ataque que envolve forçar a vítima a enviar uma solicitação HTTP a um destino alvo sem seu conhecimento ou intenção, a fim de realizar uma ação como a vítima. A causa implícita é a funcionalidade do aplicativo usando ações previsíveis em URLs /formulários, de maneira repetível. A natureza do ataque é que o CSRF explora a confiança que um site tem em um usuário. Em contrapartida, um ataque do tipo Cross-Site Scripting (XSS) explora a confiança que um usuário tem em um site. Como o XSS, os ataques CSRF não são necessariamente entre sites, mas também podem ser. A falsificação de solicitação entre sites também é conhecida por "CSRF", "XSRF", "one-click attack", "session riding", "confused deputy", e "sea surf".
	Os ataques CSRF são efetivos em várias situações, incluindo: * - A vítima tem uma sessão ativa no site de destino; * - A vítima está autenticada por meio de autenticação HTTP no site de destino; * - A vítima está na mesma rede local do site de destino. O CSRF era usado principalmente para executar ações contra um site-alvo usando os privilégios da vítima, mas técnicas recentes foram descobertas para vazamento de informações obtendo acesso às respostas. O risco de vazamento/divulgação não autorizada de informações aumenta drasticamente quando o site de destino é vulnerável a XSS, porque o XSS pode ser usado como uma plataforma para CSRF, permitindo que o ataque opere dentro dos limites da política de mesma origem.
URL	http://localhost:8080/h2-console/admin.do?jsessionid=ce55e78d9eb9a35eef4e02d1abb3cb5f
Node	

Name	http://localhost:8080/h2-console/admin.do (jsessionId)
Método	GET
Ataque	
Evidence	<form name="adminLogin" method="post" action="adminLogin.do?jsessionid=ce55e78d9eb9a35eef4e02d1abb3cb5f">
Other Info	Nenhum token Anti-CSRF conhecido [anticsrf, CSRFTOKEN, __RequestVerificationToken, csrfmiddlewaretoken, authenticity_token, OWASP_CSRFTOKEN, anoncsrf, csrf_token, _csrf, _csrfSecret, __csrf_magic, CSRF, _token, _csrf_token, _csrfToken] foi encontrado nos seguintes formulários HTML: [Form 1: "password"].
URL	http://localhost:8080/h2-console/login.jsp?jsessionid=ce55e78d9eb9a35eef4e02d1abb3cb5f
Node Name	http://localhost:8080/h2-console/login.jsp (jsessionId)
Método	GET
Ataque	
Evidence	<form name="login" method="post" action="login.do?jsessionid=ce55e78d9eb9a35eef4e02d1abb3cb5f" id="login">
Other Info	Nenhum token Anti-CSRF conhecido [anticsrf, CSRFTOKEN, __RequestVerificationToken, csrfmiddlewaretoken, authenticity_token, OWASP_CSRFTOKEN, anoncsrf, csrf_token, _csrf, _csrfSecret, __csrf_magic, CSRF, _token, _csrf_token, _csrfToken] foi encontrado nos seguintes formulários HTML: [Form 1: "driver" "name" "password" "url" "user"].
URL	http://localhost:8080/h2-console/login.do?jsessionid=ce55e78d9eb9a35eef4e02d1abb3cb5f
Node Name	http://localhost:8080/h2-console/login.do (jsessionId)(driver,language,name,password,setting,url,user)
Método	POST
Ataque	
Evidence	<form name="login" method="post" action="login.do?jsessionid=ce55e78d9eb9a35eef4e02d1abb3cb5f" id="login">
Other Info	Nenhum token Anti-CSRF conhecido [anticsrf, CSRFTOKEN, __RequestVerificationToken, csrfmiddlewaretoken, authenticity_token, OWASP_CSRFTOKEN, anoncsrf, csrf_token, _csrf, _csrfSecret, __csrf_magic, CSRF, _token, _csrf_token, _csrfToken] foi encontrado nos seguintes formulários HTML: [Form 1: "driver" "name" "password" "url" "user"].
URL	http://localhost:8080/h2-console/test.do?jsessionid=ce55e78d9eb9a35eef4e02d1abb3cb5f
Node Name	http://localhost:8080/h2-console/test.do (jsessionId)(driver,language,name,password,setting,url,user)
Método	POST
Ataque	
Evidence	<form name="login" method="post" action="login.do?jsessionid=ce55e78d9eb9a35eef4e02d1abb3cb5f" id="login">
Other Info	Nenhum token Anti-CSRF conhecido [anticsrf, CSRFTOKEN, __RequestVerificationToken, csrfmiddlewaretoken, authenticity_token, OWASP_CSRFTOKEN, anoncsrf, csrf_token, _csrf, _csrfSecret, __csrf_magic, CSRF, _token, _csrf_token, _csrfToken] foi encontrado nos seguintes formulários HTML: [Form 1: "driver" "name" "password" "url" "user"].
Instances	Systemic
	Fase: Arquitetura e Design. Use uma biblioteca verificada ou framework que não permita que essa vulnerabilidade ocorra, ou forneça construções/implementações que tornem essa vulnerabilidade mais fácil de evitar. Por exemplo, use pacotes anti-CSRF, como o OWASP CSRFGuard. Fase: Implementação.

Solution	Certifique-se de que seu aplicativo esteja livre de problemas de cross-site scripting (XSS), porque a maioria das defesas CSRF pode ser contornada usando script controlado por invasor.
	Fase: Arquitetura e Design.
	Gere um número arbitrário de uso único e exclusivo (ou Nonce = "N" de "number" - número em inglês - e "once" de "uma vez" também em inglês) para cada formulário, coloque o nonce no formulário e verifique-o ao receber o formulário. Certifique-se de que o nonce não seja previsível (CWE-330).
	Observe que isso pode ser contornado usando XSS.
	Identifique operações especialmente perigosas. Quando o usuário realizar uma operação perigosa, envie uma solicitação de confirmação separada para garantir que o usuário pretendia realizar aquela operação.
	Observe que isso pode ser contornado usando XSS.
	Utilize o controle ESAPI Session Management.
	Este controle inclui um componente para CSRF.
	Não use o método GET para qualquer solicitação que acione uma mudança de estado.
Reference	Fase: Implementação.
	Verifique o cabeçalho HTTP Referer para ver se a solicitação foi originada de uma página esperada. Isso pode interromper funcionalidades legítimas, porque os usuários ou proxies podem ter desativado o envio do Referer por motivos de privacidade.
	https://cheatsheetseries.owasp.org/cheatsheets/Cross-Site_Request_Forgery_Prevention_Cheat_Sheet.html
	https://cwe.mitre.org/data/definitions/352.html
CWE Id	352
WASC Id	9
Plugin Id	10202

Médio	Estouro de Buffer
Descrição	Buffer overflow errors are characterized by the overwriting of memory spaces of the background
URL	http://localhost:8080/h2-console/index.do?jsessionid=ce55e78d9eb9a35eef4e02d1abb3cb5f&la
Node Name	http://localhost:8080/h2-console/index.do (jsessionid,language)
Método	GET
Ataque	DitbjOLKBNPRSucmqIqajORCcTywsjCVPVcsLckoENPJdXJkKPDvvpxtMaRGvZOFQUSuQTR
Evidence	Connection: close
Other Info	Potential Buffer Overflow. The script closed the connection and threw a 500 Internal Server Error
URL	http://localhost:8080/h2-console/index.do?jsessionid=a3c7c6aee3e2505e5b91048e026ec80a&la
Node Name	http://localhost:8080/h2-console/index.do (jsessionid,language)
Método	GET
Ataque	ZXZsVgBykrqeNbuEhPqXkFGDrphrULLQPiPODgZKJuWhvVyvyZOAmrEOSKjSTYRnNoOTtRq
Evidence	Connection: close
Other Info	Potential Buffer Overflow. The script closed the connection and threw a 500 Internal Server Error
URL	http://localhost:8080/h2-console/login.do

Node Name	http://localhost:8080/h2-console/login.do ()(driver,language,name,password,setting,url,user)
Método	POST
Ataque	HvPfMhenggOOMLkZDOaqZYSIMYmJkjyjfKHdQPllXwXYPcBbxaUGXcfxyglxOQrdvyuJrMbYf
Evidence	Connection: close
Other Info	Potential Buffer Overflow. The script closed the connection and threw a 500 Internal Server Error
URL	http://localhost:8080/h2-console/settingRemove.do?jsessionId=ce55e78d9eb9a35eef4e02d1ab
Node Name	http://localhost:8080/h2-console/settingRemove.do (jsessionId)(driver,language,name,password,setting,url,user)
Método	POST
Ataque	PgvoanXoDydKRhHfELQBJTwhERSSmOFCWdxsWwWITgEsqvGdEXSgGCBWLCmkeWbKZm
Evidence	Connection: close
Other Info	Potential Buffer Overflow. The script closed the connection and threw a 500 Internal Server Error
URL	http://localhost:8080/h2-console/settingSave.do?jsessionId=ce55e78d9eb9a35eef4e02d1abb3c
Node Name	http://localhost:8080/h2-console/settingSave.do (jsessionId)(driver,language,name,password,setting,url,user)
Método	POST
Ataque	qMxExdJWqwUmTcuseGPnUbMsopausYobxpmukluYtKXcShWjPjINXiCANiNadyMDwVKLsrHX
Evidence	Connection: close
Other Info	Potential Buffer Overflow. The script closed the connection and threw a 500 Internal Server Error
Instances	5
Solution	Rewrite the background program using proper return length checking. This will require a recompilation of the program.
Reference	https://owasp.org/www-community/attacks/Buffer_overflow_attack
CWE Id	120
WASC Id	7
Plugin Id	30001

Médio	Missing Anti-clickjacking Header
Descrição	The response does not protect against 'ClickJacking' attacks. It should include either Content-Security-Policy with 'frame-ancestors' directive or X-Frame-Options.
URL	http://localhost:8080/h2-console/help.jsp
Node Name	http://localhost:8080/h2-console/help.jsp
Método	GET
Ataque	
Evidence	
Other Info	
URL	http://localhost:8080/h2-console/login.jsp
Node Name	http://localhost:8080/h2-console/login.jsp
Método	GET
Ataque	

Evidence	
Other Info	
URL	http://localhost:8080/h2-console/tools.jsp
Node Name	http://localhost:8080/h2-console/tools.jsp
Método	GET
Ataque	
Evidence	
Other Info	
Instances	Systemic
Solution	Modern Web browsers support the Content-Security-Policy and X-Frame-Options HTTP headers. Ensure one of them is set on all web pages returned by your site/app. If you expect the page to be framed only by pages on your server (e.g. it's part of a FRAMESET) then you'll want to use SAMEORIGIN, otherwise if you never expect the page to be framed, you should use DENY. Alternatively consider implementing Content Security Policy's "frame-ancestors" directive.
Reference	https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/X-Frame-Options
CWE Id	1021
WASC Id	15
Plugin Id	10020

Médio	Session ID in URL Rewrite
Descrição	URL rewrite is used to track user session ID. The session ID may be disclosed via cross-site referer header. In addition, the session ID might be stored in browser history or server logs.
URL	http://localhost:8080/h2-console/index.do?jsessionId=ce55e78d9eb9a35eef4e02d1abb3cb5f&language=ja
Node Name	http://localhost:8080/h2-console/index.do (jsessionid,language)
Método	GET
Ataque	
Evidence	ce55e78d9eb9a35eef4e02d1abb3cb5f
Other Info	
URL	http://localhost:8080/h2-console/index.do?jsessionId=ce55e78d9eb9a35eef4e02d1abb3cb5f&setting=Generic%20MariaDB
Node Name	http://localhost:8080/h2-console/index.do (jsessionid,setting)
Método	GET
Ataque	
Evidence	ce55e78d9eb9a35eef4e02d1abb3cb5f
Other Info	
URL	http://localhost:8080/h2-console/login.jsp?jsessionId=ce55e78d9eb9a35eef4e02d1abb3cb5f
Node Name	http://localhost:8080/h2-console/login.jsp (jsessionid)

Método	GET
Ataque	
Evidence	ce55e78d9eb9a35eef4e02d1abb3cb5f
Other Info	
Instances	Systemic
Solution	For secure content, put session ID in a cookie. To be even more secure consider using a combination of cookie and URL rewrite.
Reference	https://seclists.org/webappsec/2002/q4/111
CWE Id	598
WASC Id	13
Plugin Id	3

Baixo	Application Error Disclosure
Descrição	This page contains an error/warning message that may disclose sensitive information like the location of the file that produced the unhandled exception. This information can be used to launch further attacks against the web application. The alert could be a false positive if the error message is found inside a documentation page.
URL	http://localhost:8080/h2-console/index.do?jsessionId=ce55e78d9eb9a35eef4e02d1abb3cb5f&language=in
Node Name	http://localhost:8080/h2-console/index.do (jsessionid,language)
Método	GET
Ataque	
Evidence	HTTP/1.1 500
Other Info	
Instances	1
Solution	Review the source code of this page. Implement custom error pages. Consider implementing a mechanism to provide a unique error reference/identifier to the client (browser) while logging the details on the server side and not exposing them to the user.
Reference	
CWE Id	550
WASC Id	13
Plugin Id	90022

Baixo	Divulgação de informações - Mensagens de Erro de Depuração
Descrição	A resposta parecia conter mensagens de erro comuns retornadas por plataformas como ASP.NET e servidores da Web como IIS e Apache. Você pode configurar a lista de mensagens de depuração comuns.
URL	http://localhost:8080/h2-console/index.do?jsessionId=ce55e78d9eb9a35eef4e02d1abb3cb5f&language=in
Node Name	http://localhost:8080/h2-console/index.do (jsessionid,language)
Método	GET
Ataque	
Evidence	Internal Server Error
Other Info	

Instances	1
Solution	Desative as mensagens de depuração antes de enviar para a produção.
Reference	
CWE Id	1295
WASC Id	13
Plugin Id	10023

Baixo	Referer Exposes Session ID
Descrição	A hyperlink pointing to another host name was found. As session ID URL rewrite is used, it may be disclosed in referer header to external hosts.
URL	http://localhost:8080/h2-console/admin.do?jsessionId=ce55e78d9eb9a35eef4e02d1abb3cb5f
Node Name	http://localhost:8080/h2-console/admin.do (jsessionid)
Método	GET
Ataque	
Evidence	h2database.com
Other Info	
URL	http://localhost:8080/h2-console/login.jsp?jsessionId=ce55e78d9eb9a35eef4e02d1abb3cb5f
Node Name	http://localhost:8080/h2-console/login.jsp (jsessionid)
Método	GET
Ataque	
Evidence	h2database.com
Other Info	
URL	http://localhost:8080/h2-console/login.do?jsessionId=ce55e78d9eb9a35eef4e02d1abb3cb5f
Node Name	http://localhost:8080/h2-console/login.do (jsessionid)(driver,language,name,password,setting,url,user)
Método	POST
Ataque	
Evidence	h2database.com
Other Info	
URL	http://localhost:8080/h2-console/test.do?jsessionId=ce55e78d9eb9a35eef4e02d1abb3cb5f
Node Name	http://localhost:8080/h2-console/test.do (jsessionid)(driver,language,name,password,setting,url,user)
Método	POST
Ataque	
Evidence	h2database.com
Other Info	
Instances	Systemic
Solution	This is a risk if the session ID is sensitive and the hyperlink refers to an external or third party host. For secure content, put session ID in secured session cookie.
Reference	https://seclists.org/webappsec/2002/q4/111

CWE Id	598
WASC Id	13
Plugin Id	3

Informativo	Information Disclosure - Sensitive Information in URL
Descrição	A solicitação parecia conter informações confidenciais vazadas no URL. Isso pode violar a PCI e a maioria das políticas de conformidade organizacional. Você pode configurar a lista de strings para esta verificação para adicionar ou remover valores específicos para seu ambiente.
URL	http://localhost:8080/h2-console/index.do?jsessionId=ce55e78d9eb9a35eef4e02d1abb3cb5f&language=ja
Node Name	http://localhost:8080/h2-console/index.do (jsessionid,language)
Método	GET
Ataque	
Evidence	jsessionid
Other Info	The URL contains potentially sensitive information. The following string was found via the pattern: session jsessionid
URL	http://localhost:8080/h2-console/index.do?jsessionId=ce55e78d9eb9a35eef4e02d1abb3cb5f&setting=Generic%20MariaDB
Node Name	http://localhost:8080/h2-console/index.do (jsessionid,setting)
Método	GET
Ataque	
Evidence	jsessionid
Other Info	The URL contains potentially sensitive information. The following string was found via the pattern: session jsessionid
URL	http://localhost:8080/h2-console/login.jsp?jsessionId=ce55e78d9eb9a35eef4e02d1abb3cb5f
Node Name	http://localhost:8080/h2-console/login.jsp (jsessionid)
Método	GET
Ataque	
Evidence	jsessionid
Other Info	The URL contains potentially sensitive information. The following string was found via the pattern: session jsessionid
Instances	Systemic
Solution	Não passe informações confidenciais em URIs.
Reference	
CWE Id	598
WASC Id	13
Plugin Id	10024

Informativo	Modern Web Application

Descrição	The application appears to be a modern web application. If you need to explore it automatically then the Ajax Spider may well be more effective than the standard one.
URL	http://localhost:8080/h2-console/help.jsp
Node Name	http://localhost:8080/h2-console/help.jsp
Método	GET
Ataque	
Evidence	<script type="text/javascript"> location.href = 'login.jsp?jsessionId=7579927ae69f7ce1ef54e06cd43f0da3'; </script>
Other Info	No links have been found while there are scripts, which is an indication that this is a modern web application.
URL	http://localhost:8080/h2-console/login.jsp
Node Name	http://localhost:8080/h2-console/login.jsp
Método	GET
Ataque	
Evidence	<script type="text/javascript"> location.href = 'login.jsp?jsessionId=f665f8d70db2a249149d2d8cbfa69060'; </script>
Other Info	No links have been found while there are scripts, which is an indication that this is a modern web application.
URL	http://localhost:8080/h2-console/tools.jsp
Node Name	http://localhost:8080/h2-console/tools.jsp
Método	GET
Ataque	
Evidence	<script type="text/javascript"> location.href = 'login.jsp?jsessionId=02d37aa0c7ce37b590f498190b6e90ba'; </script>
Other Info	No links have been found while there are scripts, which is an indication that this is a modern web application.
Instances	Systemic
Solution	This is an informational alert and so no changes are required.
Reference	
CWE Id	
WASC Id	
Plugin Id	10109

Informativo	Solicitação de autenticação identificada
Descrição	A solicitação em questão foi identificada como uma solicitação de autenticação. O campo "Outras Informações" contém um conjunto de linhas chave=valor que identificam quaisquer campos relevantes. Se a solicitação estiver em um contexto com um Método de Autenticação definido como "Detecção Automática", esta regra alterará a autenticação para corresponder à solicitação identificada.
URL	http://localhost:8080/h2-console/settingRemove.do?jsessionId=ce55e78d9eb9a35eef4e02d1abb3cb5f
Node Name	http://localhost:8080/h2-console/settingRemove.do (jsessionid)(driver,language,name,password,setting,url,user)
Método	POST
Ataque	
Evidence	password

Other Info	userParam=user userValue=sa passwordParam=password referer=http://localhost:8080/h2-console/login.jsp? jsessionid=ce55e78d9eb9a35eef4e02d1abb3cb5f
URL	http://localhost:8080/h2-console/settingSave.do? jsessionid=ce55e78d9eb9a35eef4e02d1abb3cb5f
Node Name	http://localhost:8080/h2-console/settingSave.do (jsessionid)(driver,language,name,password,setting,url,user)
Método	POST
Ataque	
Evidence	password
Other Info	userParam=user userValue=sa passwordParam=password referer=http://localhost:8080/h2-console/login.jsp? jsessionid=ce55e78d9eb9a35eef4e02d1abb3cb5f
URL	http://localhost:8080/h2-console/test.do?jsessionid=ce55e78d9eb9a35eef4e02d1abb3cb5f
Node Name	http://localhost:8080/h2-console/test.do (jsessionid)(driver,language,name,password,setting,url,user)
Método	POST
Ataque	
Evidence	password
Other Info	userParam=user userValue= passwordParam=password referer=http://localhost:8080/h2-console/login.jsp? jsessionid=ce55e78d9eb9a35eef4e02d1abb3cb5f
URL	http://localhost:8080/h2-console/login.do
Node Name	http://localhost:8080/h2-console/login.do ()(driver,language,name,password,setting,url,user)
Método	POST
Ataque	
Evidence	password
Other Info	userParam=user userValue=sa passwordParam=password referer=http://localhost:8080/h2-console/login.jsp? jsessionid=ce55e78d9eb9a35eef4e02d1abb3cb5f
URL	http://localhost:8080/h2-console/login.do?jsessionid=ce55e78d9eb9a35eef4e02d1abb3cb5f
Node Name	http://localhost:8080/h2-console/login.do (jsessionid)(driver,language,name,password,setting,url,user)

Método	POST
Ataque	
Evidence	password
Other Info	userParam=user userValue=sa passwordParam=password referer=http://localhost:8080/h2-console/login.jsp? jsessionId=ce55e78d9eb9a35eef4e02d1abb3cb5f
Instances	5
Solution	Este é um alerta informativo e não uma vulnerabilidade, portanto não há nada a ser corrigido.
Reference	https://www.zaproxy.org/docs/desktop/addons/authentication-helper/auth-req-id/
CWE Id	
WASC Id	
Plugin Id	10111

Informativo	User Controllable HTML Element Attribute (Potential XSS)
Descrição	This check looks at user-supplied input in query string parameters and POST data to identify where certain HTML attribute values might be controlled. This provides hot-spot detection for XSS (cross-site scripting) that will require further review by a security analyst to determine exploitability.
URL	http://localhost:8080/h2-console/login.do?jsessionid=ce55e78d9eb9a35eef4e02d1abb3cb5f
Node Name	http://localhost:8080/h2-console/login.do (jsessionid)(driver,language,name,password,setting,url,user)
Método	POST
Ataque	
Evidence	
Other Info	User-controlled HTML attribute values were found. Try injecting special characters to see if XSS might be possible. The page at the following URL: http://localhost:8080/h2-console/login.do?jsessionid=ce55e78d9eb9a35eef4e02d1abb3cb5f appears to include user input in: a(n) [input] tag [value] attribute The user input found was: driver=org.h2.Driver The user-controlled value was: org.h2.driver
URL	http://localhost:8080/h2-console/login.do?jsessionid=ce55e78d9eb9a35eef4e02d1abb3cb5f
Node Name	http://localhost:8080/h2-console/login.do (jsessionid)(driver,language,name,password,setting,url,user)
Método	POST
Ataque	
Evidence	
	User-controlled HTML attribute values were found. Try injecting special characters to see if XSS might be possible. The page at the following URL:

Other Info	http://localhost:8080/h2-console/login.do?jsessionid=ce55e78d9eb9a35eef4e02d1abb3cb5f appears to include user input in: a(n) [option] tag [value] attribute The user input found was: language=pt_PT The user-controlled value was: pt_pt
URL	http://localhost:8080/h2-console/login.do?jsessionid=ce55e78d9eb9a35eef4e02d1abb3cb5f
Node Name	http://localhost:8080/h2-console/login.do (jsessionid)(driver,language,name,password,setting,url,user)
Método	POST
Ataque	
Evidence	
Other Info	User-controlled HTML attribute values were found. Try injecting special characters to see if XSS might be possible. The page at the following URL: http://localhost:8080/h2-console/login.do?jsessionid=ce55e78d9eb9a35eef4e02d1abb3cb5f appears to include user input in: a(n) [option] tag [value] attribute The user input found was: name=Generic H2 (Embedded) The user-controlled value was: generic h2 (embedded)
URL	http://localhost:8080/h2-console/login.do?jsessionid=ce55e78d9eb9a35eef4e02d1abb3cb5f
Node Name	http://localhost:8080/h2-console/login.do (jsessionid)(driver,language,name,password,setting,url,user)
Método	POST
Ataque	
Evidence	
Other Info	User-controlled HTML attribute values were found. Try injecting special characters to see if XSS might be possible. The page at the following URL: http://localhost:8080/h2-console/login.do?jsessionid=ce55e78d9eb9a35eef4e02d1abb3cb5f appears to include user input in: a(n) [option] tag [value] attribute The user input found was: setting=Generic H2 (Embedded) The user-controlled value was: generic h2 (embedded)
URL	http://localhost:8080/h2-console/login.do?jsessionid=ce55e78d9eb9a35eef4e02d1abb3cb5f

Node Name	http://localhost:8080/h2-console/login.do (jsessionid)(driver,language,name,password,setting,url,user)
Método	POST
Ataque	
Evidence	
Other Info	User-controlled HTML attribute values were found. Try injecting special characters to see if XSS might be possible. The page at the following URL: http://localhost:8080/h2-console/login.do?jsessionid=ce55e78d9eb9a35eef4e02d1abb3cb5f appears to include user input in: a(n) [input] tag [value] attribute The user input found was: url=jdbc:h2:~/test The user-controlled value was: jdbc:h2:~/test
URL	http://localhost:8080/h2-console/login.do?jsessionid=ce55e78d9eb9a35eef4e02d1abb3cb5f
Node Name	http://localhost:8080/h2-console/login.do (jsessionid)(driver,language,name,password,setting,url,user)
Método	POST
Ataque	
Evidence	
Other Info	User-controlled HTML attribute values were found. Try injecting special characters to see if XSS might be possible. The page at the following URL: http://localhost:8080/h2-console/login.do?jsessionid=ce55e78d9eb9a35eef4e02d1abb3cb5f appears to include user input in: a(n) [input] tag [value] attribute The user input found was: user=sa The user-controlled value was: sa
URL	http://localhost:8080/h2-console/test.do?jsessionid=ce55e78d9eb9a35eef4e02d1abb3cb5f
Node Name	http://localhost:8080/h2-console/test.do (jsessionid)(driver,language,name,password,setting,url,user)
Método	POST
Ataque	
Evidence	
Other	User-controlled HTML attribute values were found. Try injecting special characters to see if XSS might be possible. The page at the following URL: http://localhost:8080/h2-console/test.do?jsessionid=ce55e78d9eb9a35eef4e02d1abb3cb5f appears to include user input in: a(n) [input] tag [value] attribute

Info	The user input found was: driver=org.cloudera.impala.jdbc41.Driver The user-controlled value was: org.cloudera.impala.jdbc41.driver
URL	http://localhost:8080/h2-console/test.do?jsessionid=ce55e78d9eb9a35eef4e02d1abb3cb5f
Node Name	http://localhost:8080/h2-console/test.do (jsessionid)(driver,language,name,password,setting,url,user)
Método	POST
Ataque	
Evidence	
Other Info	User-controlled HTML attribute values were found. Try injecting special characters to see if XSS might be possible. The page at the following URL: http://localhost:8080/h2-console/test.do?jsessionid=ce55e78d9eb9a35eef4e02d1abb3cb5f appears to include user input in: a(n) [option] tag [value] attribute The user input found was: language=ru The user-controlled value was: ru
URL	http://localhost:8080/h2-console/test.do?jsessionid=ce55e78d9eb9a35eef4e02d1abb3cb5f
Node Name	http://localhost:8080/h2-console/test.do (jsessionid)(driver,language,name,password,setting,url,user)
Método	POST
Ataque	
Evidence	
Other Info	User-controlled HTML attribute values were found. Try injecting special characters to see if XSS might be possible. The page at the following URL: http://localhost:8080/h2-console/test.do?jsessionid=ce55e78d9eb9a35eef4e02d1abb3cb5f appears to include user input in: a(n) [option] tag [value] attribute The user input found was: name=Generic Impala The user-controlled value was: generic impala
URL	http://localhost:8080/h2-console/test.do?jsessionid=ce55e78d9eb9a35eef4e02d1abb3cb5f
Node Name	http://localhost:8080/h2-console/test.do (jsessionid)(driver,language,name,password,setting,url,user)
Método	POST
Ataque	

Evidence	
Other Info	User-controlled HTML attribute values were found. Try injecting special characters to see if XSS might be possible. The page at the following URL: http://localhost:8080/h2-console/test.do?jsessionid=ce55e78d9eb9a35eef4e02d1abb3cb5f appears to include user input in: a(n) [option] tag [value] attribute The user input found was: setting=Generic Impala The user-controlled value was: generic impala
URL	http://localhost:8080/h2-console/test.do?jsessionid=ce55e78d9eb9a35eef4e02d1abb3cb5f
Node Name	http://localhost:8080/h2-console/test.do (jsessionid)(driver,language,name,password,setting,url,user)
Método	POST
Ataque	
Evidence	
Other Info	User-controlled HTML attribute values were found. Try injecting special characters to see if XSS might be possible. The page at the following URL: http://localhost:8080/h2-console/test.do?jsessionid=ce55e78d9eb9a35eef4e02d1abb3cb5f appears to include user input in: a(n) [input] tag [value] attribute The user input found was: url=JjGoXzGv The user-controlled value was: jjgoxzgv
URL	http://localhost:8080/h2-console/test.do?jsessionid=ce55e78d9eb9a35eef4e02d1abb3cb5f
Node Name	http://localhost:8080/h2-console/test.do (jsessionid)(driver,language,name,password,setting,url,user)
Método	POST
Ataque	
Evidence	
Other Info	User-controlled HTML attribute values were found. Try injecting special characters to see if XSS might be possible. The page at the following URL: http://localhost:8080/h2-console/test.do?jsessionid=ce55e78d9eb9a35eef4e02d1abb3cb5f appears to include user input in: a(n) [input] tag [value] attribute The user input found was: user=pWMIRBJO The user-controlled value was:

	pwmIrbjo
Instances	12
Solution	Validate all input and sanitize output it before writing to any HTML attributes.
Reference	https://cheatsheetseries.owasp.org/cheatsheets/Input_Validation_Cheat_Sheet.html
CWE Id	20
WASC Id	20
Plugin Id	10031